

GUÍA METODOLÓGICA DETALLADA

Encuesta de Madurez LINDDUN/LIINE4DU 2025-2026

Marco teórico, diseño, aplicación y análisis de resultados

"Una metodología sin teoría es un mapa sin territorio. Una teoría sin metodología es un territorio sin mapa. Este documento es, modestamente, los dos a la vez."

1. FUNDAMENTOS TEÓRICOS

1.1 El Marco LINDDUN: Origen y Evolución

El marco LINDDUN (*Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness, Non-compliance*) fue desarrollado por el grupo DistriNet de KU Leuven (Universidad Católica de Lovaina) en 2010, como respuesta a la ausencia de un marco sistemático equivalente a STRIDE orientado específicamente a la privacidad de las personas físicas, no a los activos organizacionales.

Su premisa fundacional es epistemológicamente distinta de la ciberseguridad tradicional: mientras que la seguridad de la información protege la **confidencialidad, integridad y disponibilidad** de los sistemas, LINDDUN protege la **no vinculabilidad, la anonimidad/pseudonimidad, la negación plausible, la indetectabilidad, la confidencialidad de los datos, la consciencia y el cumplimiento** de los **individuos**.

En 2025-2026, LINDDUN ha alcanzado su mayor nivel de madurez institucional:

- Reconocido por el NIST como marco primario de modelado de amenazas de privacidad.
- Incorporado en la norma ISO 27550 sobre ingeniería de privacidad.
- Extendido formalmente para sistemas de IA Generativa (KU Leuven + Huawei, 2026).
- Adoptado por la AEPD como base de LIINE4DU 1.0 (octubre 2024).
- Publicada la versión LINDDUN MAESTRO en *Software and Systems Modeling* (noviembre 2025).

1.2 El Marco LIINE4DU: La Adaptación Española

La Agencia Española de Protección de Datos publicó en octubre de 2024 LIINE4DU 1.0 (*Linking, Identifying, Inaccuracy, Non-repudiation, Exclusion, Data Breach, Deception, Data Disclosure, Unawareness/Unintervenability*), una adaptación de LINDDUN orientada específicamente al cumplimiento del RGPD y la realización de Evaluaciones de Impacto en Protección de Datos (EIPDs).

Las principales diferencias respecto a LINDDUN son:

- **Eliminación** de Non-compliance como categoría independiente (queda absorbida en Data Breach y Deception).
- **Incorporación** de Inaccuracy (inexactitud de datos), Exclusion (obstaculización de derechos), Data Breach (brecha de datos) y Deception (engaño deliberado).
- **Reorganización** en dos grupos: amenazas sobre derechos individuales (Grupo A) y amenazas con incumplimiento directo del RGPD (Grupo B).

1.3 El Modelo de Madurez de Cinco Niveles

La escala de respuesta de la encuesta está calibrada sobre el modelo de madurez de cinco niveles inspirado en el CMMI (*Capability Maturity Model Integration*) y en el *Privacy Maturity Model* del AICPA/CICA, adaptado al contexto del RGPD y LINDDUN:

Nivel	Denominación	Características
1 - Inexistente	Ad hoc / Caótico	Sin procesos documentados; respuesta puramente reactiva; riesgo regulatorio inmediato.
2 - Inicial	Reactivo / Intuitivo	Procesos informales; dependencia de personas clave; cumplimiento parcial sin evidencias.
3 - Definido	Documentado / Estandarizado	Procesos documentados y comunicados; cumplimiento formal; evidencias disponibles para auditoría.
4 - Gestionado	Medido / Controlado	KPIs definidos y monitorizados; mejora basada en datos; integración entre funciones.
5 - Optimizado	Continuo / Proactivo	Mejora continua integrada; privacy by design sistémico; benchmarking externo; innovación en privacidad.

2. DISEÑO DE LA ENCUESTA

2.1 Estructura Modular

La encuesta se organiza en **11 módulos**:

Módulo	Contenido	N.º Ítems	Indicador LINDDUN/LIINE4DU
M0	Perfil organizacional	6	Contextual (no puntuable)
M1	Vinculación	5	L (Linking)
M2	Identificabilidad	4	I (Identifying)
M3	No Repudio	4	NR (Non-repudiation)
M4	Detección	4	D (Detecting)
M5	Divulgación de Datos	5	DD (Data Disclosure)
M6	Desconocimiento	5	U (Unawareness/Uninter venability)
M7	Incumplimiento	5	NC + LIINE4DU (Data Breach)
M8	Inexactitud y Exclusión	3	LIINE4DU (Inaccuracy + Exclusion)
M9	Gobernanza	3	Transversal
M10	Tecnología e IA	4	Transversal (AI Act + ZTA)
MF	Preguntas abiertas	4	Cualitativo

Total ítems puntuables: 42

Total ítems cualitativos: 4 (no puntuables directamente)

Total ítems de perfil: 6 (no puntuables)

2.2 Tipos de Ítem

La encuesta combina cuatro tipos de ítems:

1. Ítem de opción única descriptiva (IOUD): El encuestado selecciona la opción que mejor describe su situación actual. Escala A–E mapeada a 1–5. Es el tipo predominante (75% de los ítems).
2. Ítem de selección múltiple (ISM): El encuestado puede marcar todas las opciones que aplican. Se puntúa según el número y nivel de las opciones seleccionadas.
3. Ítem de opción única nominal (IOUN): Preguntas de perfil sin escala de madurez (M0).
4. Ítem abierto (IA): Permite recoger información cualitativa no estructurada (Sección Final).

Ítem de opción única descriptiva (IOUD): El encuestado selecciona la opción que mejor describe su situación actual. Escala A–E mapeada a 1–5. Es el tipo predominante (75% de los ítems).

Ítem de selección múltiple (ISM): El encuestado puede marcar todas las opciones que aplican. Se puntúa según el número y nivel de las opciones seleccionadas.

Ítem de opción única nominal (IOUN): Preguntas de perfil sin escala de madurez (M0).

Ítem abierto (IA): Permite recoger información cualitativa no estructurada (Sección Final).

2.3 Sistema de Ponderación

Los módulos tienen pesos diferenciados en el cálculo del IGM, reflejando su importancia relativa en el contexto regulatorio español 2025–2026:

Módulo	Peso en IGM
M1 - Linking	10%
M2 - Identifying	12%
M3 - Non-repudiation	8%
M4 - Detecting	8%
M5 - Data Disclosure	15%
M6 - Unawareness	12%
M7 - Non-compliance	15%
M8 - Inaccuracy/Exclusion	8%
M9 - Gobernanza	7%
M10 - Tecnología e IA	5%
Total	100%

Nota metodológica: Los módulos M5, M6 y M7 tienen mayor peso por representar las áreas con mayor volumen de sanciones AEPD en 2025 y por su impacto directo en los derechos de los interesados.

2.4 Fórmula del Índice de Madurez Global (IGM)

$$IGM = \sum_{m=1}^{10} \left(w_m \times \frac{\sum_{i=1}^{n_m} P_{m,i}}{n_m \times 5} \right) \times 100$$

Donde:

- w_m = peso del módulo m (ver tabla anterior)
- $P_{m,i}$ = puntuación del ítem i del módulo m (escala 1–5)
- n_m = número de ítems del módulo m
- El resultado es un porcentaje (0–100%) equivalente al IGM

Interpretación del IGM:

Rango IGM	Nivel de Madurez	Color semafórico
0% - 39%	Muy bajo	● Rojo
40% - 59%	Bajo	● Naranja
60% - 74%	Medio	● Amarillo
75% - 89%	Alto	● Verde claro
90% - 100%	Muy alto (Excelencia)	♥ Verde oscuro

3. ADMINISTRACIÓN DE LA ENCUESTA

3.1 Modalidades de Aplicación

a) Autodiagnóstico individual: Un solo responsable (DPO, CISO) completa la encuesta con visión holística de la organización. Ventaja: rapidez. Limitación: sesgo de confirmación y ángulo ciego de perspectiva única.

b) Sesión colaborativa multidisciplinar (recomendada): Equipo diverso (DPO + CISO + arquitecto de sistemas + responsable legal + representante de negocio) completa la encuesta en sesión estructurada de 3-4 horas. Permite triangulación de perspectivas y alineamiento del equipo directivo.

c) Encuesta distribuida por módulos: Cada módulo es completado por el responsable más cualificado de esa área. El facilitador consolida las respuestas. Más precisa pero requiere coordinación.

d) Auditoría asistida: Un auditor externo experto en LINDDUN/LIINE4DU administra la encuesta mediante entrevistas semiestructuradas y revisión de evidencias documentales. La opción más rigurosa y la más adecuada para preparar una EIPD compleja o una auditoría externa.

3.2 Protocolo de Administración

Antes de la sesión:

1. Distribuir el documento de la encuesta con al menos 5 días de antelación para revisión previa.
2. Solicitar a los participantes que recopilen la documentación relevante: Registro de Actividades, EIPDs existentes, contratos DPA, política de logs, mapa de sistemas de IA.
3. Designar un facilitador (idealmente el DPO o un consultor externo) responsable de guiar la sesión y garantizar respuestas basadas en evidencias, no en aspiraciones.
4. Establecer las reglas de la sesión: se responde sobre la situación actual documentada y verificable, no sobre intenciones o proyectos en curso.

Durante la sesión:

1. Comenzar con el Módulo 0 (Perfil) para contextualizar.
2. Para cada ítem, leer la pregunta en voz alta y permitir que cada participante exprese su percepción antes de consensuar la respuesta.
3. Documentar los desacuerdos entre participantes: son indicadores de áreas de mejora comunicacional y organizativa.

4. Registrar evidencias que soportan las respuestas (nombre del documento, fecha, responsable).
5. Anotar acciones de mejora identificadas durante la sesión.

Después de la sesión:

1. Calcular el IGM por módulo y global (ver plantilla Excel, archivo (e)).
2. Identificar los tres módulos de menor puntuación como áreas prioritarias de mejora.
3. Elaborar el Reporte Ejecutivo (ver plantilla, archivo (f)).
4. Programar la siguiente sesión de revisión (recomendado: anual o tras cambios relevantes en el sistema, la normativa o el contexto de amenazas).

3.3 Requisitos del Facilitador

El facilitador de la sesión debe:

- Conocer el marco LINDDUN/LIINE4DU a nivel conceptual y práctico.
- Tener formación en protección de datos (mínimo CIPP/E o equivalente).
- Ser capaz de distinguir entre cumplimiento formal y cumplimiento material.
- Mantener neutralidad ante las respuestas: su función es facilitar la reflexión, no juzgar ni tranquilizar.
- Conocer el sector de la organización encuestada para contextualizar las preguntas.

4. ANÁLISIS E INTERPRETACIÓN DE RESULTADOS

4.1 Análisis Cuantitativo

Nivel 1 – Puntuación por ítem: Cada ítem A=1, B=2, C=3, D=4, E=5.

Nivel 2 – Puntuación por módulo: Media aritmética de los ítems del módulo.

Nivel 3 – IGM: Suma ponderada de las puntuaciones de módulo (ver fórmula sección 2.4).

Nivel 4 – Radar chart de madurez: Representación visual de las puntuaciones por módulo en un gráfico de araña (radar plot), permitiendo identificar de forma inmediata los desequilibrios en el perfil de madurez.

Nivel 5 – Benchmarking: Comparación del IGM con la media sectorial (cuando hay datos disponibles) y con el Indicador de Madurez RGPD del Observatorio de la Privacidad (ISMS Forum, 2026).

4.2 Análisis Cualitativo

Las preguntas abiertas de la Sección Final se analizan mediante:

- **Análisis de contenido temático:** Identificación de categorías de obstáculos, inversiones y percepciones.
- **Análisis de frecuencia:** ¿Qué obstáculos son más recurrentes en el sector?
- **Análisis de correlación:** ¿Los obstáculos mencionados se correlacionan con las áreas de menor puntuación cuantitativa?

4.3 Patrones de Respuesta y Señales de Alerta

Los siguientes patrones de respuesta merecen atención especial del facilitador:

Patrón de "cumplimiento de papel": Puntuaciones altas en M7 (Non-compliance / EIPDs / DPO) pero bajas en M1–M5 (indicadores técnicos). Indica organizaciones que han invertido en documentación pero no en implementación técnica de Privacy by Design.

Patrón de "seguridad sin privacidad": Puntuaciones altas en M4 (Detecting) y M7 (medidas de seguridad) pero bajas en M3 (Non-repudiation: logs excesivos) y M6 (Unawareness: información al empleado). Común en organizaciones con cultura de seguridad fuerte pero que no han trasladado esa sensibilidad a la dimensión de privacidad.

Patrón de "IA sin gobernanza": Puntuaciones altas en M10 (adopción de IA) pero bajas en M2 (Identifying: ataques de inferencia) y M7 (AI Act compliance). Indica organizaciones que adoptan tecnología IA sin haber adaptado su marco de gobernanza.

Patrón de "PYME sincera": Puntuaciones consistentemente en nivel B–C con alta coherencia entre módulos. Indica organizaciones pequeñas con recursos limitados pero conciencia realista de su situación. Son las que más se benefician del plan de mejora gradual.

4.4 Nivel Mínimo Recomendado por Sector

Basado en el contexto regulatorio español 2025–2026:

Sector	IGM Mínimo Recomendado	Justificación
Sanidad y datos genéticos	75%	Art. 9 RGPD + EIPD obligatoria
Servicios financieros	70%	NIS2 + RGPD + Basilea IV
Administración Pública	70%	ENS + RGPD + NIS2
Educación (menores)	70%	Art. 9 RGPD + LOPDGDD Art. 7
Tecnología / IA	75%	AI Act + RGPD Art. 22
Resto de sectores	60%	RGPD estándar

5. LIMITACIONES METODOLÓGICAS

5.1 Sesgo de Deseabilidad Social

Los encuestados pueden tender a responder la opción que creen que es la "correcta" en lugar de la que refleja la realidad. Mitigación: enfatizar que la honestidad es la única forma de obtener un plan de mejora útil; anonimizar los resultados individuales en análisis sectoriales.

5.2 Sesgo de Marco de Referencia

Los encuestados con mayor formación en LINDDUN pueden interpretar las preguntas de forma más rigurosa. Mitigación: incluir la narrativa explicativa (archivo (c)) como material de preparación previo.

5.3 Validez Temporal

El contexto regulatorio y técnico evoluciona rápidamente. Esta versión de la encuesta incorpora los desarrollos hasta abril de 2026 (AI Act, LINDDUN Maestro, LIINE4DU 1.0, ENISA ETL 2025). Se recomienda revisión anual.

5.4 Autoevaluación vs. Auditoría

La encuesta es un instrumento de autodiagnóstico, no de auditoría. Las puntuaciones obtenidas reflejan la percepción de la organización sobre su nivel de madurez, que puede diferir de una evaluación independiente. Para decisiones de alto impacto (certificación, due diligence, preparación para inspección), se recomienda complementar con auditoría externa.

6. MARCO NORMATIVO DE REFERENCIA

Normativa	Relevancia para la Encuesta
RGPD (Reglamento 2016/679)	Marco principal: Arts. 5, 13, 14, 17, 22, 25, 32, 33, 34, 35, 37–39
LOPDGDD (LO 3/2018)	Adaptación española del RGPD: Arts. 7, 22, 37–41
AI Act (Reglamento 2024/1689)	Arts. 5, 9, 10, 13, 22, 27; Prohibiciones desde feb. 2025
NIS2 (Directiva 2022/2555)	Obligaciones para operadores esenciales e importantes
ENS (RD 311/2022)	Sector público español y proveedores de la Administración
eIDAS2 (Reglamento 2024/1183)	Identidad digital europea: impacto en Identifying y Non-repudiation
ISO/IEC 27001:2022	SGSI: base técnica para M7, M9, M10
ISO/IEC 27701:2019	Extensión privacidad de ISO 27001: base para M5, M6, M9
ISO/IEC 42001:2023	Sistema de gestión de IA: base para M10

Guía elaborada conforme a los estándares metodológicos del NIST Privacy Framework, la documentación oficial de LINDDUN (KU Leuven, DistriNet) y la guía de EIPDs de la AEPD. Versión 1.0 — Abril 2026.